REPORT DI PROGETTO

BUILD WEEK – PROGETTO DI RETE PER LA COMPAGNIA THETA

Sborotech

SOLUTIONS & INNOVATION

INTRODUZIONE

Sborotech SRL è stata incaricata dalla società **Theta** di progettare e implementare un'infrastruttura di rete sicura ed efficiente per la loro sede aziendale, distribuita su **6 piani** con un totale di **120** postazioni di lavoro.

Il progetto include, oltre alle postazioni, una serie di componenti:

- un **web server** esposto su rete *DMZ*
- un **firewall perimetrale**
- un sistema **NAS** per lo storage centralizzato
- tre sistemi **IDS/IPS** per il monitoraggio e la prevenzione delle intrusioni.

SCOPO DEL DOCUMENTO

Il presente documento ha lo scopo di fornire alla dirigenza di **Theta** una visione completa e chiara del lavoro svolto: dalla progettazione della **topologia** di rete al **preventivo** di spesa, fino ai **test** di **sicurezza** effettuati e alle relative **raccomandazioni**.

Il report è redatto in modo da essere accessibile anche a lettori non tecnici, garantendo trasparenza e tracciabilità di ogni scelta progettuale.

PREVENTIVO, MATERIALE E MANODOPERA

MATERIALE OCCORRENTE

Tutto il materiale riportato di seguito **NON** sará addebitato nel costo finale di tale servizio poiché già fornito dall'azienda in questione:

A. **FIREWALL PERIMETRALE**: € 3500
PERCHÉ: È la prima linea di difesa. Separa la rete aziendale da Internet.
FUNZIONE: Gestisce le VPN per il lavoro agile, filtra il traffico in entrata e in uscita tramite policy rigorose e crea la **DMZ** (Zona Demilitarizzata) per il Web Server.

B. **SWITCH DI ACCESSO** (1 per piano) € 800 cad.
PERCHÉ: Con 20 computer per piano, uno switch da **24** porte è l'ideale (lasciando margine per stampanti
AP Wi-Fi).
FUNZIONE: Supportano le VLAN. Questo significa che se un computer al Piano 1 viene infettato da un virus,
Il traffico malevolo non può propagarsi automaticamente al Piano 6 perché le reti sono logicamente separate.

C. **WEB SERVER** (DVWA / Metasploitable) €0
PERCHÉ: Ospita i servizi web della compagnia.
FUNZIONE: Essendo una macchina volutamente vulnerabile (DVWA), viene installata all'interno di una DMZ isolata. In questo modo, anche se un hacker dovesse prendere il controllo del server, non avrebbe accesso diretto ai PC dei dipendenti o al NAS aziendale.

D. **NAS** (Network Attached Storage) € 3000
PERCHÉ: Centralizza il salvataggio dei dati e i backup.
FUNZIONE: Configurato in RAID 6, garantisce che i dati siano salvi anche se due dischi rigidi si rompono contemporaneamente. È il cuore della "Business Continuity".

E. **IDS/IPS** (3 Unità) € 2000 cad.
PERCHÉ: Per un monitoraggio profondo del traffico che il firewall da solo non può vedere.
FUNZIONE (Posizionamento strategico):
   - *Sensore Esterno*: Tra firewall e internet (rileva attacchi brute-force).
   - *Sensore DMZ*: Monitora specificamente il traffico verso il Web Server DVWA.
   - *Sensore Interno*: Monitora il traffico tra le VLAN dei piani e il NAS per rilevare movimenti laterali di malware o tentativi di esfiltrazione dati.

SINTESI DEI VANTAGGI

- **SICUREZZA "ZERO TRUST":** Ogni piano è isolato e il server vulnerabile non può contaminare la rete.
- **SCALABILITÀ**: L'infrastruttura a 6 piani è pronta per l'aggiunta di altri dispositivi (Wi-Fi, VoIP) senza cambiare l'architettura.
- **MONITORAGGIO PROATTIVO**: Grazie ai 3 IDS/IPS, il team IT riceve alert in tempo reale su ogni tentativo di intrusione.

Ripetiamo che i costi della parte hardware **NON** saranno addebitati perché già in possesso dall'azienda Theta Spa. Il costo in visione è solo indicativo.

DAILY DUTIES/PREVENTIVO MANODOPERA

Dato che i cavi sono già pronti, ci concentriamo esclusivamente sugli apparati attivi.

- **GIORNO 1**: Hardware & Core Switching
   - Montaggio apparati nei rack di piano.
   - Configurazione del Core Switch e delle 6 VLAN.
   - Test di connettività tra i piani e il centro stella.

- **GIORNO 2**: Security & DMZ
   - Configurazione Firewall (Policy, VPN, NAT).
   - Setup della DMZ e installazione del Web Server (DVWA) e del NAS.
   - Isolamento logico delle reti per garantire che il server vulnerabile non "veda" i PC.

- **GIORNO 3**: Monitoring & Tuning
   - Installazione e configurazione dei 3 IDS/IPS.
   - Test di vulnerabilità e verifica delle regole di prevenzione intrusioni.
   - Consegna credenziali e documentazione tecnica alla compagnia Theta.

- **CONSIDERAZIONI IMPORTANTI**
  Per rispettare la scadenza dei 3 giorni, è necessario che:
   - Gli armadi rack siano liberi e accessibili.
   - Il cablaggio esistente sia etichettato correttamente (sapere quale cavo va a quale piano).
   - Le credenziali e i parametri della linea internet siano già disponibili.

Qualora le "CONSIDERAZIONI IMPORTANTI" non saranno rispettate o la parte hardware non sará presente, i costi potrebbero aumentare.

Ricapitolando:

- GIORNO 1: €3000
- GIORNO 2: €6500

- GIORNO 3: €4500

TOTALE LAVORI: €14000

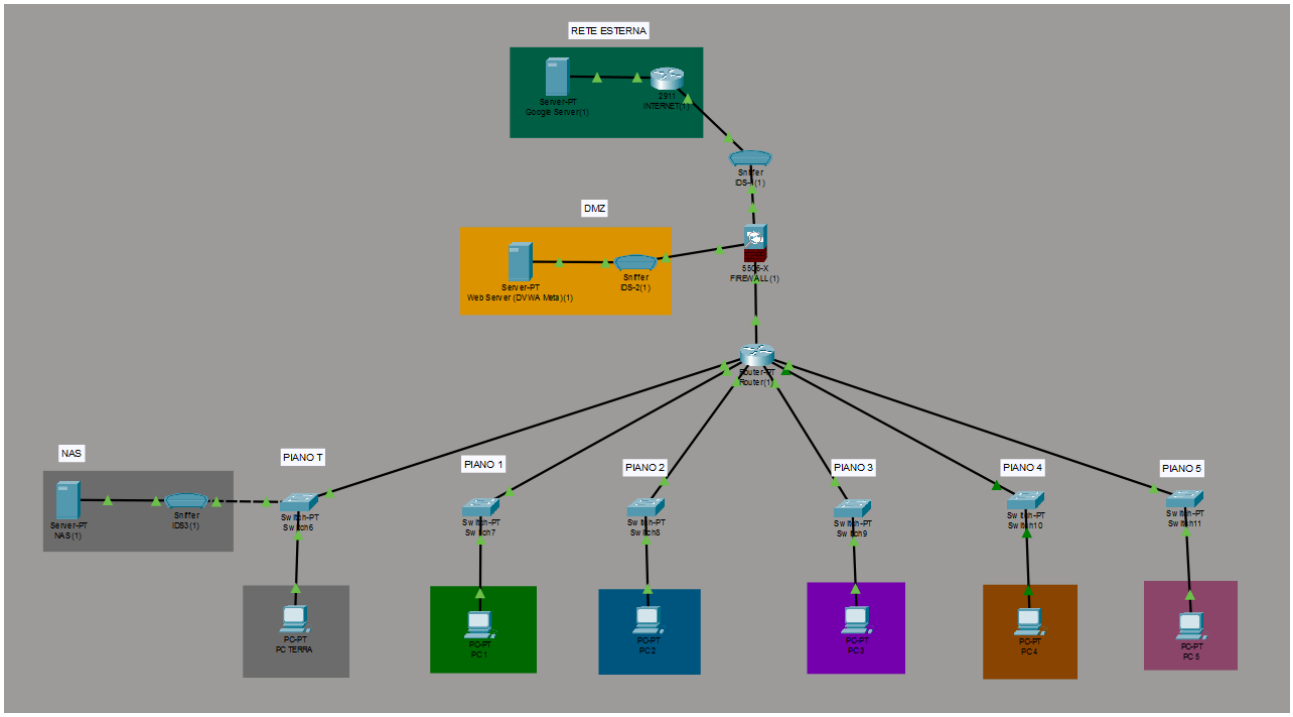
DESCRIZIONE DELL'INFRASTRUTTURA

COMPONENTISTICA

Per la realizzazione dell'infrastruttura di rete della sede Theta sono stati utilizzati i seguenti dispositivi:

- 6 Switch (uno per piano).
- 1 Router interno.
- 1 Router esterno.
- 1 Firewall perimetrale.
- 3 Sistemi IDS/IPS.
- 1 NAS (Network Attached Storage).
- 1 Web Server (DMZ).
- 120 Computer (20 per piano).

TOPOLOGIA



La rete è suddivisa in **tre** zone principali: la **rete interna** aziendale, la **DMZ** e la **rete esterna** (Internet).

Come illustrato nella figura sopra, la topologia dell'infrastruttura è descritta in dettaglio dalla tabella di configurazione riportata di seguito.

Zona / Piano	Dispositivo	Quantità	Indirizzo IP / Subnet	Note di Collegamento
Piano Terra (LAN)	PC Desktop	20	192.168.10.0 /24	Collegati allo Switch 0
	NAS Server	1	192.168.10.3 /24	Storage di rete (Switch 0)
	IDS-1 (Sniffer)	1	—	Monitoraggio traffico interno
	Router Interno	1	192.168.1.1 /24 192.168.10.1 /24 192.168.20.1 /24 192.168.30.1 /24 192.168.40.1 /24 192.168.50.1 /24 192.168.60.1 /24	Gateway principale (Core)
FIREWALL	Firewall ASA 5506-X	1	192.168.1.254 /24 192.168.5.1 /24 200.0.0.2 /24	Router Interno Web Server Internet (WAN)
Zona DMZ	Web Server	1	192.168.5.10/24	Connesso al Firewall via IDS2
	IDS-2 (Sniffer)	1	-	Monitoraggio Traffico DMZ

Zona / Piano	Dispositivo	Quantità	Indirizzo IP / Subnet	Note di Collegamento
Piano 1	PC Desktop	20	192.168.20.0 /24	Collegati allo Switch 1
Piano 2	PC Desktop	20	192.168.30.0 /24	Collegati allo Switch 2
Piano 3	PC Desktop	20	192.168.40.0 /24	Collegati allo Switch 3
Piano 4	PC Desktop	20	192.168.50.0 /24	Collegati allo Switch 4
Piano 5	PC Desktop	20	192.168.60.0 /24	Collegati allo Switch 5
Internet (Esterna)	Server Pubblico	1	8.8.8.8	Server Google Simulator
	Router Esterno	1	200.0.0.1/24	WAN simulator

C'è solo un piccolo accorgimento di sicurezza; il web server ha **2** modi a cui possono accedervi:

- DALL'ESTERNO usando non l'indirizzo IP del web server, ma tramite indirizzo IP pubblico assegnatogli dal firewall (200.0.0.10);
- DALL'INTERNO, invece, usando tranquillamente l'indirizzo IP proprio del web server (192.168.5.10).

Come servizio a valore aggiunto, Sborotech Srl offre ai propri clienti lo **sviluppo di tool personalizzati** finalizzati al **miglioramento della sicurezza** delle infrastrutture IT aziendali.

TEST EFFETTUATI

Tra i diversi programmi proprietari sviluppati dalla Sborotech Srl, rientra uno scanner di porte TCP sviluppato in Python, basato sulla libreria standard socket.

L'adozione di questo tool consente alle aziende di ottenere diversi **benefici** in ambito sicurezza, tra cui:

- **INDIVIDUAZIONE** di porte aperte non autorizzate;
- **RIDUZIONE** della superficie di attacco esposta verso l'esterno;
- **VERIFICA** dell'efficacia delle configurazioni firewall e delle policy di rete.

SCANNER DI PORTE

Il software consente di analizzare un **host target** attraverso i seguenti passaggi principali:

- **ACQUISIZIONE** dell'indirizzo IP di destinazione e del **range** di porte da analizzare;
- **ELABORAZIONE** e suddivisione dell'intervallo di porte **specificato**;
- **ESECUZIONE** di tentativi di connessione **TCP** su ciascuna porta tramite la creazione di **socket** dedicati;
- **GENERAZIONE** di un **output** strutturato sulla base dei risultati ottenuti.

```
Please, insert the target IP to scan: 10.20.21.2
Please, insert the port range to scan [0-65535]: 0-3306
Scanning port 3306 (3307/3307)...
--- Scan Results ---
[✔] OPEN  -> 10.20.21.2:21 (ftp)
[✔] OPEN  -> 10.20.21.2:22 (ssh)
[✔] OPEN  -> 10.20.21.2:23 (telnet)
[✔] OPEN  -> 10.20.21.2:25 (smtp)
[✔] OPEN  -> 10.20.21.2:53 (domain)
[✔] OPEN  -> 10.20.21.2:80 (http)
[✔] OPEN  -> 10.20.21.2:111 (sunrpc)
[✔] OPEN  -> 10.20.21.2:139 (netbios-ssn)
[✔] OPEN  -> 10.20.21.2:445 (microsoft-ds)
[✔] OPEN  -> 10.20.21.2:512 (exec)
[✔] OPEN  -> 10.20.21.2:513 (login)
[✔] OPEN  -> 10.20.21.2:514 (shell)
[✔] OPEN  -> 10.20.21.2:1099 (rmiregistry)
[✔] OPEN  -> 10.20.21.2:1524 (ingreslock)
[✔] OPEN  -> 10.20.21.2:2049 (nfs)
[✔] OPEN  -> 10.20.21.2:2121 (iprop)
[✔] OPEN  -> 10.20.21.2:3306 (mysql)

====================
   SCAN COMPLETED
====================
```

Il **funzionamento** dello strumento si basa sul **principio** delle connessioni TCP: una porta viene considerata APERTA se accetta una connessione in **ingresso**, mentre viene classificata come CHIUSA o non raggiungibile in caso contrario.

Inoltre, lo strumento supporta le attività di **monitoraggio** e **gestione** dei sistemi, permettendo di identificare i servizi attivi su un determinato host e le relative porte di ascolto (ad esempio: 80 per HTTP, 22 per SSH).

Infine, lo scanner rappresenta un **valido supporto** per le attività di **audit** e **compliance**, contribuendo a:

- **ESEGUIRE** controlli periodici di sicurezza;
- **FACILITARE** le verifiche interne;
- **GARANTIRE** l'allineamento alle policy aziendali e agli standard di riferimento.

In aggiunta, è stato sviluppato un applicativo in **Python** dedicato all'invio di **richieste** HTTP (GET, POST, PUT, DELETE) verso **web server**, con l'obiettivo di analizzarne le risposte e verificare quali metodi risultino effettivamente abilitati.

VERIFICA DEI VERBI HTTP

Il programma consente, dato un URL in input, di andare a verificare quali comandi HTTP siano abilitati e quali no sulla pagina di destinazione, evidenziando il rischio nel caso alcuni di essi, come PUT, DELETE, PATCH, e TRACE, siano stati abilitati

```
Metodo  : HEAD
URL     : http://192.168.4.100/dvwa/login.php
Status  : 200
Tempo   : 168.6 ms
→ Invio OPTIONS...

Metodo  : OPTIONS
URL     : http://192.168.4.100/dvwa/login.php
Status  : 200
Tempo   : 261.7 ms
→ Invio TRACE...

Metodo  : TRACE
URL     : http://192.168.4.100/dvwa/login.php
Status  : 200
Tempo   : 104.8 ms

RIEPILOGO

METODO    STATUS    TEMPO      NOTE
GET       200    183.3 ms   Abilitato
POST      200    251.4 ms   Abilitato
PUT       200    279.1 ms   ⚠ ABILITATO — RISCHIOSO
DELETE    200    188.1 ms   ⚠ ABILITATO — RISCHIOSO
PATCH     200    198.6 ms   ⚠ ABILITATO — RISCHIOSO
HEAD      200    168.6 ms   Abilitato
OPTIONS   200    261.7 ms   Abilitato
TRACE     200    104.8 ms   ⚠ ABILITATO — RISCHIOSO
```

Infine, il programma raccoglie tutte le risposte del server in una tabella, evidenziando, con colori differenti, quali comandi sono abilitati, quali no e quali sono rischiosi.

RACCOMANDAZIONI SULLA SICUREZZA

I test effettuati hanno riscontrato più di una vulnerabilità sulla sicurezza dell'azienda Theta Spa:

- L'analisi della scansione delle porte ha evidenziato la presenza di diversi servizi attivi sul server, tra i più rilevanti abbiamo: l'accesso a Telnet sulla porta 23, HTTP per l'erogazione delle applicazioni web, SSH per l'accesso remoto e MySQL sulla porta 3306 per la gestione del database.
- L'verifica dei verbi http, come si evince dall'immagine precedente, sulla pagina del Web Server dell'azienda risultano abilitato tutti i comandi testati, inclusi **PUT, DELETE, PATCH E TRACE**.

RISULATO SCANNER DI PORTE

La presenza del servizio **Telnet** sulla porta 23 costituisce una CRITICITÀ ELEVATA, in quanto utilizza un protocollo **non cifrato** che trasmette credenziali e dati **in chiaro**, rendendoli facilmente **intercettabili** tramite

tecniche di **sniffing**. Questo espone il sistema a rischi di **furto** di **credenziali**, accessi non autorizzati e attacchi di tipo **man-in-the-middle**.

Sebbene tali servizi siano **funzionali**, la loro esposizione aumenta la superficie di attacco del sistema. In particolare, i **servizi web** rappresentano il **principale punto di ingresso** per attacchi applicativi, mentre l'accesso **SSH** può essere soggetto a tentativi di intrusione tramite **forza bruta**. La presenza del database accessibile sulla porta *3306* costituisce una CRITICITÀ RILEVANTE, in quanto potrebbe essere sfruttata per attacchi come la **SQL Injection**, con il rischio di accesso non autorizzato o **manipolazione** dei dati.

RISULTATO VERBI HTTP

Il fatto che i verbi siano tutti abilitati costituisce una grave falla di sicurezza del Web Server. Si consiglia di utilizzare questo tool da noi fornito periodicamente per controllare lo status dei servizi e dei comandi del Web Server. Consigliamo inoltre di disabilitare, almeno per gli utenti esterni, i comandi sopracitati nella pagina web del Web server, questo perché:

A. **PUT** = chiunque acceda al Web Server, che sia dalla rete **interna** o **dall'esterno**, con questo comando potrebbe andare a modificare per intero i dati del sito web a suo piacimento;
B. **DELETE** = chiunque acceda al Web Server, che sia dalla rete interna o dall'esterno, con questo comando potrebbe andare a cancellare parte dei dati presenti all'interno del sito web a suo piacimento;
C. **PATCH** = chiunque acceda al Web Server, che sia dalla rete interna o dall'esterno, con questo comando potrebbe andare a modificare parte dei dati contenuti nel sito web a suo piacimento;
D. **TRACE** = chiunque acceda al Web Server, che sia dalla rete interna o dall'esterno, potrebbe utilizzare questo comando, che rimanda indietro al client esattamente la stessa richiesta ricevuta, per attacchi di tipo cross-site tracing.

Nel complesso, la configurazione risulta operativa e presenta **margini di miglioramento** in termini di sicurezza. È quindi necessario **limitare** l'esposizione dei servizi ai soli indispensabili, **proteggere** adeguatamente l'accesso remoto, impedire l'accesso diretto al database dall'esterno e implementare sistemi di monitoraggio e filtraggio del traffico.

L'aggiornamento costante dei sistemi e una **configurazione più restrittiva** consentono di ridurre significativamente i rischi e migliorare la **protezione** dell'infrastruttura.

IMPLEMENTAZIONI AGGIUNTIVE

Come servizio aggiuntivo, la **Sborotech Srl** offre ai propri clienti la possibilità di **acquistare** gli script sopra citati e molti altri, al fine di utilizzarli per i processi di **manutenzione** periodici all'interno della vostra rete.

Qualora foste interessati si prega di contattare **via mail** il Payroll Executive della nostra società Ancona Leandro.

CONCLUSIONE

Il presente progetto ha permesso di **definire** e **implementare** un'infrastruttura di rete completa e sicura per la sede aziendale di Theta, rispondendo **pienamente** ai requisiti inizialmente concordati. La soluzione adottata garantisce una segmentazione efficace della rete, la protezione del perimetro tramite firewall e sistemi IDS/IPS, e un accesso sicuro ai servizi esposti all'esterno attraverso la zona **DMZ**.

Sborotech SRL rimane a disposizione di Theta per qualsiasi chiarimento, integrazione o sviluppo futuro dell'infrastruttura.

P.S: In allegato trovate anche la fattura.

Team incaricato del progetto:

- *Ancona Leandro, Payroll Executive*
- *Di Genova Francesco, Python Engineer*
- *Pistollato Davide, Project Manager*
- *Ventanni Lorenzo, IT Engineer*
- *Ventura Lorenzo, Python Engineer*